



Proyecto Unidad 2 Seguridad Informática

Desarrollo de Software para Seguridad

Ricardo Pérez
riperez@utalca.cl

Introducción

Los *keyloggers* son un tipo de herramienta que registran cada tecla que se pulsa en una computadora, a menudo sin el permiso ni el conocimiento del usuario. Un keylogger puede estar basado en hardware o software, y se puede usar como herramienta lícita de control TI. Sin embargo, los keyloggers también se pueden utilizar con fines delictivos. Por regla general, los keyloggers son un spyware malicioso que se usa para capturar información confidencial, como contraseñas o información financiera que posteriormente se envía a terceros para su explotación con fines delictivos.

El objetivo de este proyecto es desarrollar un *keylogger* de acuerdo a las necesidades planteadas, que no sea detectado por la víctima y que permita capturar toda la información ingresada por el teclado, incorporando mecanismos de cifrado, transmisión segura de datos y técnicas de evasión.

Ejercicio 1 (20 puntos): Desarrollo del Keylogger

Utilizando el lenguaje de programación de su preferencia, desarrolle un keylogger que permita capturar toda la información ingresada por teclado en el dispositivo de la víctima. Puede asumir que la víctima utiliza cualquier sistema operativo (Android, Linux, macOS o Windows). Todo el desarrollo debe realizarse en un entorno controlado (por ejemplo a través de máquinas virtuales propias), nunca sobre dispositivos de terceros sin autorización explícita.

Se recomienda no reutilizar fragmentos de código de otros compañeros, ya que se utilizarán herramientas automáticas para verificar la originalidad del código implementado.

- Documente detalladamente el código (propósito de cada función, parámetros y flujo de ejecución).
- Analice qué tipo de información **no** es capturada por su implementación (p.ej. campos de contraseña en navegadores, caracteres especiales, etc.) y justifique por qué.
- Implemente persistencia: el keylogger debe sobrevivir a un reinicio del sistema operativo de la víctima. Documente el mecanismo de persistencia utilizado.
- Muestre evidencias de funcionamiento (capturas de pantalla o fragmentos de log obtenido).

Ejercicio 2 (20 puntos): Cifrado y envío de los datos

Una vez capturada la información del teclado, esta debe cifrarse utilizando un mecanismo de cifrado seguro y enviarse periódicamente hacia el dispositivo del atacante.

- **Justifique** la elección del algoritmo de cifrado. Distinga explícitamente entre funciones de hash (p.ej. MD5, SHA-256) y algoritmos de cifrado simétrico o asimétrico (p.ej. AES-256-GCM, RSA). Explique por qué MD5 **no** es una opción válida de cifrado.
- Explique cómo se gestiona la clave de cifrado: ¿está embebida en el ejecutable o se genera dinámicamente? Discuta las implicancias de seguridad de cada enfoque.
- Envíe los datos cifrados a su dispositivo de forma periódica. El intervalo de envío debe ser configurable. Los datos recibidos deben almacenarse para análisis posterior.
- Una vez recibida la información, descifre y muestre todo lo que la víctima ha escrito hasta el momento.
- Muestre evidencias en cada etapa: captura, cifrado, transmisión y descifrado.

Ejercicio 3 (20 puntos): MITM, Evasión y Mitigación

Lleve a cabo un ataque Man-in-the-Middle (MITM) que tenga como objetivo el dispositivo de la víctima y demuestre que, a pesar de interceptar la información transmitida, la comunicación del keylogger no puede ser descifrada por un tercero.

- **Ejecutable:** el malware debe entregarse como un binario o ejecutable compilado. No se aceptará un script Python sin compilar. Si desarrolló el keylogger en Python, debe convertirlo a ejecutable (p.ej. con PyInstaller o Nuitka) y documentar el proceso.
- **Evasión:** demuestre que su ejecutable no es detectado al menos por una herramienta IDS/Antivirus conocida. Como evidencia complementaria, suba el ejecutable a VirusTotal, documente el porcentaje de detección obtenido y analice qué motores lo detectan y bajo qué categoría (firma, heurística, comportamiento).
- **Mitigación:** redacte un análisis de las alternativas disponibles para usuarios y especialistas TI para detectar y mitigar este tipo de amenaza.

Ejercicio 4 (10 puntos): Informe Técnico de Amenaza

Redacte un informe técnico breve (máximo 3 páginas) describiendo su malware como si fuera una amenaza real documentada, siguiendo el estilo de reportes de inteligencia de amenazas (p.ej. FortiGuard Threat Report). El informe debe incluir:

- Nombre y descripción de la amenaza.
- Vector de infección y sistema operativo objetivo.
- TTPs (Tácticas, Técnicas y Procedimientos) según MITRE ATT&CK.
- Indicadores de Compromiso (IoCs): hashes, puertos, patrones de tráfico.
- Impacto potencial y recomendaciones de mitigación.

Requisitos

- El desarrollo del proyecto es **individual**.
- Todo el desarrollo y las pruebas deben realizarse en **entornos virtualizados propios**. Queda estrictamente prohibido ejecutar el keylogger en dispositivos de terceros o en redes no autorizadas.
- El proyecto debe ser defendido en la primera semana de julio (fecha a coordinar con el profesor).
- Deberán subir a alguna plataforma un **video demostrativo** donde tengan la cámara encendida y expliquen el procedimiento utilizado. Este video debe ser subido **un día antes** de la defensa del proyecto.
- El código fuente debe subirse a un repositorio (GitHub, GitLab u otro) con historial de commits que evidencie el desarrollo progresivo.

Pauta de evaluación

Criterio	Descripción	Puntaje
Ejercicio 1 - Desarrollo del Keylogger		20 pts
Captura de teclado	El keylogger captura correctamente las teclas pulsadas en el SO objetivo.	8
Persistencia	Implementa un mecanismo de persistencia funcional tras reinicio.	6
Documentación del código	Código comentado detalladamente; se explica el flujo y cada función.	4
Análisis de limitaciones	Identifica qué información no captura y justifica la razón técnica.	2
Ejercicio 2 - Cifrado y envío de datos		20 pts
Elección y justificación del cifrado	Selecciona un algoritmo de cifrado apropiado (no hash) y lo justifica correctamente. Distingue hash de cifrado.	6
Gestión de clave	Explica e implementa la gestión de la clave de cifrado con análisis de implicancias de seguridad.	4
Envío periódico cifrado	Envía datos cifrados de forma periódica; el intervalo de envío es configurable.	6
Descifrado	Descifra correctamente los datos recibidos y los muestra en claro.	4
Ejercicio 3 - MITM, Evasión y Mitigación		20 pts
Ataque MITM	Demuestra que el tráfico interceptado no puede descifrarse sin la clave.	6

Continúa en la página siguiente...

Criterio	Descripción	Puntaje
Ejecutable y evasión	Entrega binario compilado; evidencia de no detección en IDS/Antivirus; análisis de Virus-Total.	8
Mitigación	Análisis fundamentado de contramedidas para usuarios y especialistas TI.	6
Ejercicio 4 - Informe Técnico de Amenaza		10 pts
Compleitud del informe	Incluye todos los elementos solicitados: vector, TTPs, IoCs, impacto.	6
Calidad y redacción	Redacción profesional, clara y coherente con el estilo de un reporte de threat intelligence.	4
Defensa en Tiempo Real (condición de aprobación)		30 pts
Durante la defensa, el profesor podrá solicitar modificaciones al proyecto en tiempo real, sin acceso a herramientas de inteligencia artificial. El estudiante deberá implementar los cambios solicitados directamente sobre su código, explicar sus decisiones de diseño y demostrar comprensión cabal del funcionamiento de su implementación. Esta instancia constituye la condición de aprobación del proyecto: un puntaje inferior a 15/30 en esta sección implica la reprobación del proyecto con nota 1,0, independientemente del puntaje obtenido en los ejercicios anteriores. Los cambios solicitados pueden incluir, entre otros: ■ Modificar el algoritmo de cifrado o el modo de operación utilizado. ■ Ajustar el intervalo de envío o el mecanismo de almacenamiento de los datos. ■ Explicar y modificar el mecanismo de persistencia implementado. ■ Agregar o modificar el filtrado de teclas capturadas. ■ Demostrar en vivo el flujo completo: captura → cifrado → transmisión → descifrado.		
Total		100 pts

Advertencia: El uso de inteligencia artificial generativa durante la defensa en tiempo real constituye falta académica grave y resultará en la reprobación inmediata del proyecto. El profesor podrá solicitar al estudiante que muestre el historial de comandos, commits del repositorio o cualquier otro elemento que permita verificar la autoría del trabajo.